

Report: Information Security Management system for the World Health Organization



About This Report:

- This document demonstrates security testing performed in a controlled lab environment using intentionally vulnerable machines.
- All testing conducted on dedicated lab systems
- No real systems or data were compromised
- Primary goal: Show all found vulnerabilities.
- These exercises help understand attacker methodologies to build better defenses.
- The test was performed on 02nd February, 2026.
- **Some of the policies and recommendations given in this report are based on pure speculations, since all the information needed is not publicly available.**

Index

About This Report:	2
1st Identification	4
Critical Assets Affected:	4
Vulnerabilities Identified:	4
2nd Protection	4
Preventive Measures TechCo Should Have Implemented:	4
3rd Detection	5
Monitoring Solutions:	5
Alert Protocol:	5
4th Response	5
Incident Response Plan Steps:	5
Phase 1: Immediate Actions	6
Phase 2: Containment & Eradication	6
Phase 3: Communication	6
IRT Roles & Responsibilities:	6
5th Recovery	7
System & Data Restoration Steps:	7
Business Continuity During Recovery:	7
6th Continuous Improvement	7
Post-Incident Evaluation Method:	7
7th Consulted Sources	8
1. NIST Cybersecurity Framework (CSF)	8
2. NIST Incident Handling Guide	8
3. NIST Security Controls	8
4. NIST Risk Assessment Guide	8
5. CISA Ransomware Guide	8
6. NIST Ransomware Profile	9
7. Email Authentication Protocols and Other Tools	9
8. Industry Best Practices	9
9. Zero Trust Security Model	9
10. Tools & Technologies Cited	9

1st ISMS scope for WHO.

ISMS Scope Statement.

The ISMS applies to all information assets, personnel, processes, and technology involved in the WHO's Global Health Emergency and Response operations,

Including:

- **Information Assets:** Electronic health records, outbreak surveillance data, research datasets, internal communications, staff records, financial data, and WHO digital platforms (e.g., COVID-19 Dashboards, IHR Portal).
- **Physical Locations:** WHO headquarters (Geneva), regional offices (e.g., AFRO, EMRO), data centers, and designated secure server rooms.
- **Virtual Boundaries:** WHO corporate network, Azure & AWS cloud environments, Microsoft 365, Salesforce CRM, and mobile device management (MDM) systems.
- **Processes:** Data collection, analysis, reporting, sharing with member states, incident response, and business continuity planning.
- **Personnel:** All employees, contractors, consultants, and interns working under WHO's Global Health Emergency Division.

Excluding:

- WHO member states' independent systems and data.
- Personal devices not managed under WHO MDM.
- Legacy systems scheduled for decommissioning within 6 months.
- Publicly available WHO website content (non-sensitive).

Stakeholders:

- **Management:** CIO, CISO, Director of Health Emergencies Programme.
- **IT/Security:** Network Admins, SOC Analysts, Data Protection Officer.
- **Operational:** Epidemiologists, Data Scientists, Field Officers.
- **External:** Member State Health Authorities, Partner NGOs, Cloud Providers.

Objectives:

- Protect sensitive global health data from unauthorized access, loss, or alteration.
- Ensure continuous availability of critical health information during emergencies.
- Comply with WHO data protection policies, GDPR, and ISO 27001:2022.

2nd Risk Assessment Results.

Methodology: ISO 27005 – Risk Assessment Approach.

Asset	Threat	Vulnerability	CVE	Likelihood	Impact	Risk Level
Outbreak Surveillance Data	Unauthorized access by external actors	Weak API authentication	CVE-2022-21449 CVE-2020-14750	High	Critical	High
Staff Credentials	Phishing attack	Lack of MFA	CVE-2022-30129 CVE-2023-23397	High	High	High
Azure Cloud Storage	Data exfiltration	Misconfigured access policies	CVE-2022-37967 CVE-2021-42306	Medium	Critical	High
Mobile Field Devices	Theft/loss	Unencrypted devices	CVE-2023-4863 CVE-2022-20210	Medium	High	Medium
WHO Website	DDoS attack	Insufficient bandwidth scaling	CVE-2021-34473 CVE-2018-11776	Low	Medium	Low
Internal Collaboration Tools (e.g., SharePoint)	Malware delivery via infected documents	Outdated document viewers / macros enabled	CVE-2022-30190 CVE-2023-38831	Medium	High	Medium
Database Servers (Health Data)	SQL injection / data breach	Unpatched database software	CVE-2022-21500 CVE-2021-38647	High	Critical	High

Top Risks Identified:

Data Breach of Sensitive Health Information. Could lead to misuse of outbreak data, public panic, loss of trust.

Ransomware Attack on WHO Network. Could disrupt emergency response operations during health crises.

Insider Threat (Accidental/Malicious). Unauthorized data sharing or deletion by staff.

Risk Treatment Plan.

- **High Risks:** Treat immediately (implement controls within 3 months).
- **Medium Risks:** Mitigate within 6~12 months.
- **Low Risks:** Accept or monitor.

3rd Selected Controls.

Aligned with ISO 27001 Annex A & WHO Security Policy.

Control ID	ISO 27001 Control	Description	Risk Mitigation
A.5.7	Threat Intelligence	Subscribe to health-sector threat feeds	Advanced Persistent Threats (APTs)
A.5.17	Authentication Mechanisms	Implement MFA for all remote access	Credential theft
A.8.10	Information Deletion	Secure sanitization of decommissioned devices	Data leakage
A.8.23	Data Masking	Mask sensitive data in non-production environments	Unauthorized internal access
A.8.31	Data Leakage Prevention	Deploy DLP on endpoints and email	Accidental data exposure
A.8.28	Secure Coding	Developer training & SAST tools	Application vulnerabilities

Implementation Plan.

Short-term (0–3 months): MFA rollout, endpoint encryption, backup verification.

Mid-term (3–12 months): DLP deployment, network segmentation, security awareness training.

Long-term (12+ months): Zero-trust architecture, advanced threat hunting.

4th Security Policies & Procedures

Information Security Policy.

- WHO is committed to protecting the confidentiality, integrity, and availability of global health information

Access Control Policy.

- Role-Based Access Control (RBAC) for health data systems.
- Password Policy: Minimum 12 characters, 90-day rotation, MFA required.
- Access Review: Quarterly review of user privileges.

Incident Response Procedure.

- **Detection:** SOC monitors 24/7 via SIEM (Microsoft Sentinel).
- **Response:** Isolate affected systems, preserve evidence, notify WHO Legal & Communications.
- **Recovery:** Restore from immutable backups, conduct post-incident review.

Data Backup & Recovery Policy.

- **Backup Frequency:** Critical data, real-time replication; Important data daily.
- **Storage:** 3~2~1 rule (3 copies, 2 media types, 1 offline copy).
- **Testing:** Quarterly recovery drills.

Security Awareness & Training Program.

- **Mandatory training:** Annual security training for all staff.
- **Phishing simulations:** Monthly tests for high-risk departments.
- **Field staff guidelines:** Secure handling of health data in conflict zones.

5th ISMS Manual.

Content

Introduction: Purpose, scope, objectives

Leadership & Commitment: Management roles, policy endorsement

Planning: Risk assessment methodology, treatment plan

Support: Resource allocation, competence, awareness

Operation: Control implementation, change management

Performance Evaluation: Monitoring, KPIs, internal audit schedule

Improvement: Non-conformity handling, corrective actions

Appendices: Risk register, control matrix, templates

Key Sections:

- **Risk Assessment Methodology:** Based on ISO 27005, using WHO's internal risk criteria.
- **Roles & Responsibilities:** Defined for ISMS Manager, Data Owners, Incident Responders.

KPIs:

- % of systems encrypted.
- Mean time to detect/respond to incidents.
- Employee training completion rate.
- Review Cycle: ISMS reviewed annually by top management; policies reviewed every 2 years or after major incidents.

6th Source Integration

- **Project Section** Primary Sources.
- **Scope Definition** ISO 27001:2022 Cl. 4.3, WHO Privacy Policy.
- **Risk Assessment** ISO 27005, NIST SP 800-30.
- **Control Selection** ISO 27001 Annex A, CIS Controls v8.
- **Security Policies** WHO policies, GDPR, ISO 27002.
- **ISMS Manual** ISO 27001 Clauses 4–10.
- **Incident Response** WHO Cyber Response Plan, NIST SP 800-61.
- **CVE Reference** MITRE Database, Exploit-DB.
- Industry Best Practices.
- **Zero Trust Security Model** Referenced for future-state architecture.
- **Tools & Technologies Cited** Microsoft Defender for Endpoints, Microsoft Sentinel, Microsoft Azure, Amazon Web Services, Microsoft Intune, Microsoft Purview.